

Contents

1	権限設計書 (メイン)	1
1.1	1. 文書概要	1
1.1.1	1.1 目的	1
1.1.2	1.2 対象範囲	1
1.1.3	1.3 版数	1
1.1.4	1.4 関連ドキュメント	1
1.2	2. ロール一覧	2
1.3	3. 権限フラグ定義 (account_permissions.permission_kind 5 値)	2
1.3.1	3.1 権限フラグ概要	2
1.3.2	3.2 主管 SCR / FR 対応	2
1.3.3	3.3 オーナー専有機能 (メンバーには account_permissions で付与不可)	2
1.4	4. 画面別権限マトリクス (§ 3.2 から移管)	2
1.5	5. 機能別権限	3
1.6	6. API 別権限	4
1.7	7. 契約別利用制限 / 運営者上書き	4
1.7.1	7.1 単一プランの利用上限 (11_ 課金請求設計書.md § 3 参照)	4
1.7.2	7.2 80/100/125% 三段階アクション (11_ 課金請求設計書.md § 8 の参照)	5
1.8	8. 権限不足・契約上書き時の動作	5
1.9	9. 緊急時のみ可操作 (§ 3.2.1-2 から移管)	5
1.9.1	9.1 「△ 緊急時のみ可」操作の発動条件	5
1.9.2	9.2 緊急区分 × 検知ハンドラ × 承認 SLA	6
1.10	10. 未決事項	6
1.11	11. 変更履歴	6

1 権限設計書 (メイン)

1.1 1. 文書概要

1.1.1 1.1 目的

メインシステムの権限モデル (オーナー / メンバー / エンドユーザー)、メンバー権限フラグ 5 種、画面別・機能別・API 別の操作可否、**契約別利用上書き** を一元化する。

1.1.2 1.2 対象範囲

- 対象: 利用者ロール (admin / service_operator / end_user)、メンバー権限フラグ 5 種 (faq:manage / chat:respond / users:manage / project:manage / logs:view)、オーナー専有機能、契約別利用上書き
- 対象外: 運営者ロール (02_ 運営者システム/個別設計書群/05_ 権限設計書.md 参照)、認証フロー (09_ 認証認可設計書.md 参照)

1.1.3 1.3 版数

項目	値
版数	1.0
更新日	2026-05-17

1.1.4 1.4 関連ドキュメント

ドキュメント名	役割	参照先
索引	11 ドキュメント体系の俯瞰	00_ 索引.md
認証・認可設計書	認可判定ロジック / Principal	09_ 認証認可設計書.md
画面設計書	画面別表示制御	02_ 画面設計書.md
API 設計書	API 別権限	03_API 設計書.md
課金・請求設計書	契約別利用上書き (owner_quota_overrides 等)	11_ 課金請求設計書.md
エラー設計書	権限不足時のエラー	06_ エラー設計書.md
テーブル定義書	account_permissions / account_project_grants	04_ テーブル定義書.md

1.2 2. ロール一覧

(§3.1から移管)

ロール ID	ロール名	概要	利用者	DB 値
OWNER	オーナーアカウント	契約あたり1アカウント固定、全権 + オーナー専有機能	契約代表者	role='admin' AND is_owner=1 AND owner_account_id=id
MEMBER	メンバーアカウント	0..N、権限フラグ + プロジェクト割当てで制御	契約参加者	role='admin' AND is_owner=0 AND owner_account_id=<owner_id>
END_USER	エンドユーザー	ウィジェット利用者 (自分の問い合わせ ID のみ)	一般訪問者	role='end_user'
SERVICE_OPERATOR	運用者	本 SaaS 提供者 (運営者側)	運営事業者	role='service_operator'

1.3 3. 権限フラグ定義 (account_permissions.permission_kind 5 値)

(§3.2.0 から移管)

1.3.1 3.1 権限フラグ概要

permission_id	表示名 (UI)	できること
faq:manage	FAQ 管理	FAQ の登録・編集・削除・公開、FAQ AI 下書き生成、FAQ インポート
chat:respond	個別チャット対応	未解決質問の閲覧・対応状態更新・担当割当て、個別チャット返信、対応不要終了
users:manage	ユーザー管理	メンバーの招待・権限フラグ変更・停止・削除、招待再送 (オーナー対象は除く)
project:manage	プロジェクト設定	プロジェクトの作成・編集・削除、ウィジェット設定、許可ドメイン設定
logs:view	ログ参照	質問ログ閲覧、自契約分の監査ログ閲覧、データエクスポート、未解決質問・個別チャット内容の閲覧

1.3.2 3.2 主管 SCR / FR 対応

permission_id	主な操作対象	オーナーとの関係
faq:manage	SCR-012(FAQ 管理)、FR-040~046, FR-104, FR-310	オーナーは常時保持
chat:respond	SCR-013(個別チャット)、SCR-011(未解決質問)の案件状態 / 担当者変更、FR-070~079, FR-086(SCR-011 のチャット履歴は閲覧のみ。返信は SCR-013 が正本)	オーナーは常時保持
users:manage	SCR-017(ユーザー管理)、FR-015~021 系列	オーナーは常時保持し、保持メンバーがいなくても運用継続可
project:manage	SCR-010 / SCR-014、FR-030~036, FR-150	オーナーは常時保持
logs:view	SCR-015、質問ログ・自契約監査ログ、FR-070, NFR-602 系列	オーナーは常時保持

1.3.3 3.3 オーナー専有機能 (メンバーには account_permissions で付与不可)

- ・課金 (SCR-015 の月次予算変更 / 支払い方法変更)
- ・退会 (SCR-024)
- ・規約再同意 (SCR-025 の同意 / 不同意)

UI 上は非表示 + API は 403(E-AUTHZ-OWNER-ONLY)。

1.4 4. 画面別権限マトリクス (§3.2 から移管)

操作分類	オーナー	faq:m	chat:re	users:n	project:	logs:v	end_us	service_operator
ダッシュボード (自分の通知・お知らせ受信箱)	○	○	○	○	○	○	×	×

操作分類	オーナー	faq:m	chat:re	users:n	project:l	logs:v	end_us	service_operator
FAQ 登録・編集・公開	○	○	×	×	×	×	×	△(運営者復元時のみ)
FAQ AI 下書き生成	○	○	×	×	×	×	×	×
プロジェクト管理	○	×	×	×	○	×	×	△(運営者復元時のみ)
メンバー招待・権限フラグ変更・停止・削除	○	×	×	○	×	×	×	×
未解決質問閲覧	○	×	○	×	×	○	×	△(障害調査時のみ)
個別チャット返信	○	×	○	×	×	×	自分のみ	×
個別チャット閲覧	○	×	○	×	×	○	自分のみ	△(障害調査時のみ)
質問ログ閲覧	○	×	×	×	×	○	×	×
監査ログ閲覧(自契約)	○	×	×	×	×	○	×	○(全契約)
課金情報閲覧・変更	○(専有)	×	×	×	×	×	×	△(訂正・サポート時のみ)
退会申請・解約	○(専有)	×	×	×	×	×	×	×
規約再同意の承諾	○(専有)	×	×	×	×	×	×	×
データエクスポート	○	×	×	×	×	○	×	×
契約無効化(サスペンション)	×	×	×	×	×	×	×	○
契約物理削除	×	×	×	×	×	×	×	○(退会後の自動バッチ)
プロンプトテンプレート編集	×	×	×	×	×	×	×	○(運営者のみ)
案件「終了」確定	○	×	○	×	×	×	×	×
案件「解決済み」	○	×	○	×	×	×	×	×
お知らせ閲覧(自契約)	○	○	○	○	○	○	×	△(運用調査時のみ)
お知らせ既読化	○	○	○	○	○	○	×	×
お知らせ作成・配信	×	×	×	×	×	×	×	○

凡例: ○ = 常時可、△ = 「緊急時のみ可」 (§ 9 参照)、自分のみ = 自分の問い合わせ ID 範囲内のみ、× = 不可

1.5 5. 機能別権限

主要機能と権限フラグの対応:

機能 ID	機能名	必要権限	オーナー	制限事項
F-AUTH-*	認証	不要	○	-
F-PRJ-*	プロジェクト	project:manage	○	削除は再認証必須
F-FAQ-*	FAQ 管理	faq:manage	○	公開ガード (draft → published 直接遷移禁止)
F-INQ-*	未解決質問	chat:respond	○	closed 遷移は admin の明示操作のみ (FR-079)
F-CHAT-*	個別チャット	chat:respond	○	部屋クローズ / 再オープン は再認証必須
F-WIDGET-*	ウィジェット設定	project:manage	○	API キーローテーションは再認証必須

機能 ID	機能名	必要権限	オーナー	制限事項
F-BILL-*	課金	オーナー専有	○	月次予算変更は再認証必須
F-USER-*	ユーザー管理	users:manage	○	招待 / 編集 / 停止 / 削除 / 強制ログアウトは再認証必須
F-ACC-*	アカウント設定 / 退会	オーナー専有	○	退会は再認証必須
F-NOTIF-*	お知らせ	全 admin	○	既読化のみ
F-LEGAL-*	規約 / 同意	オーナー専有 (同意) / 全ユーザー (閲覧)	○	-

1.6 6. API 別権限

03_API 設計書.md を正本とする。主要 API:

API	メソッド	必要権限	オーナー専有	再認証	関連エラー ID
POST /auth/login	POST	不要	-	-	E-AUTH-*
POST /projects	POST	project:manage	-	-	E-AUTHZ-FORBIDDEN
DELETE /projects/{id}	DELETE	project:manage	-	○	-
POST /faqs / PATCH / DELETE	*	faq:manage	-	DELETE のみ○	-
POST /faqs/{id}/publish	POST	faq:manage	-	-	E-BIZ-FAQ-PUBLISH(公開ガード)
POST /inquiries/{id}/close	POST	chat:respond	-	○	-
POST /chat-rooms/{id}/close	POST	chat:respond	-	○	-
GET /usage / GET /billing/invoices	GET	オーナー専有	○	-	E-AUTHZ-OWNER-ONLY
PATCH /billing/monthly-budget-limit	PATCH	オーナー専有	○	○	-
POST /members/invite / PATCH /members/{id}/*	POST/PATCH	users:manage or オーナー	-	○	E-AUTHZ-OWNER-PROTECTED
POST /withdrawal-requests	POST	オーナー専有	○	○	-
POST /terms/agree	POST	オーナー専有 (承諾)	○	-	-

1.7 7. 契約別利用制限 / 運営者上書き

1.7.1 7.1 単一プランの利用上限 (11_課金請求設計書.md §3 参照)

MVP は単一プラン (完全従量課金 + 月次無料枠 + 14 日トライアル)。プラン階層による差別化はない。利用上限は **owner_quota_overrides.resource_kind** で統一実装される (テーブル定義書 04 § 3.26 参照)。

resource_kind	用途	主管 SCR(運営者)
widget_ask_per_min	ウィジェット質問レート	SCR-093
widget_inquiry_per_min	ウィジェット未解決質問送信レート	SCR-093
widget_chat_per_min	ウィジェットチャット投稿レート	SCR-093
email_per_hour	メール送信レート	SCR-093
admin_api_per_min	管理 API レート	SCR-093

1.7.2 7.2 80/100/125% 三段階アクション (11_ 課金請求設計書.md §8 の参照)

データ種別	80%	100%	125%
質問数	inbox 通知 (normal)	inbox + email(high)、拒否しない (事後課金)	翌 1 時間レート制限 1/2 + 運営者エスカレーション
FAQ 件数	inbox 通知	新規登録拒否 (編集可)	+ 運営者エスカレーション
個別チャット部屋数	inbox 通知	新規作成拒否 (返信可)	+ 運営者エスカレーション

詳細は 11_ 課金請求設計書.md §8 を正本とする。

1.8 8. 権限不足・契約上書き時の動作

ケース	システム動作	画面表示	メッセージ ID	関連エラー ID
権限不足 (faq:manage 未保持で SCR-012 編集)	403 統一	「権限がありません」 + オーナーへ連絡誘導	MSG-COMMON-AUTHZ-403	E-AUTHZ-FORBIDDEN
オーナー境界違反 (他契約のリソース参照)	404 偽装 (403 だと相手契約の存在が漏れる)	「リソースが見つかりません」	MSG-COMMON-NOT-FOUND	E-AUTHZ-OWNER-BOUNDARY
プロジェクト割当不足	404 偽装	「リソースが見つかりません」	MSG-COMMON-NOT-FOUND	E-AUTHZ-PROJECT-DENIED
オーナー専有機能 (is_owner=0 でアクセス)	403 + 専用コード、UI 非表示	「この機能はオーナーのみご利用いただけます」	MSG-COMMON-OWNER-ONLY	E-AUTHZ-OWNER-ONLY
オーナー保護違反 (オーナー停止 / 削除)	403	「オーナーアカウントは停止・削除できません」	MSG-COMMON-OWNER-PROTECTED	E-AUTHZ-OWNER-PROTECTED
自己操作不可 (自分の users:manage 剥奪)	403、UI 非活性	「自分の権限は剥奪できません」	MSG-COMMON-SELF-MUTATION	E-AUTHZ-SELF-MUTATION
契約停止中 (contract_status=suspended)	403 + 専用コード、課金画面 / 退会画面 / データエクスポートのみ許可	サスペンション理由 + 再決済誘導	MSG-BILL-CONTRACT-SUSPENDED	E-BIZ-CONTRACT-SUSPENDED
月次無料枠 100% 超過 (質問数以外)	429 + Retry-After	「上限に到達しました」 + 課金ダッシュボード誘導	MSG-QUOTA-*	E-BIZ-QUOTA-EXCEEDED

詳細は 06_ エラー設計書.md §5 を正本とする。

1.9 9. 緊急時のみ可操作 (§3.2.1-2 から移管)

1.9.1 9.1 「△ 緊急時のみ可」操作の発動条件

条件	実装方針 (メイン側)
1. サポートチケット ID 必須	連携 IF #4 / #5 / #6 / #12 のリクエスト JSON に ticket_id フィールドを必須化。メイン側で空文字検証 + 監査ログ記録
2. 運営者 2 名の承認 (自己承認不可)	顧客管理側で承認を取得し、結果を連携 IF 経由で伝搬。メイン側はメタフィールド approvals[] (承認者 2 名分) の検証 (承認者 ID が異なる、承認時刻が 24 時間以内、kid 検証) を実施

条件	実装方針 (メイン側)
3. 管理者ユーザーへの即時通知	メイン側でinbox_messagesレコードを生成(category=system、importance=high)+ メール送信を Queue 投入
4. 監査ログ必須記録	<resource>.<verb>.by_operator 形式の action コードで audit_logs に記録。retention_class=operator_high_priv(5 年保持)

1.9.2 9.2 緊急区分 × 検知ハンドラ × 承認 SLA

緊急区分	検知ハンドラ	承認 SLA	エスカレーション経路
重大障害	monitoring:main_outage 監視 / 連携 IF #2 ヘルスチェック (5s × 3 連続失敗)	15 分以内に 2 名承認	RB-021(メイン障害時の運営者側縮退運転) と連動
全員ロックアウト	audit_logs(auth.locked) 集約検知 (該当契約内全 admin が auth.locked 状態)	30 分以内に CS マネージャーへ通報	サポート窓口経由でオーナーと連絡、紙ベース回復コード (RB-014) も可
セキュリティインシデント	NFR-602c 監査ログ完全性検証バッチ / SIEM / 不正アクセス検知 (FR-178)	即時 PagerDuty 起動	セキュリティ責任者 → CTO → 運営本部
法令対応	(運用側で個別判断)	個別判断	法務 → CTO

1.10 10. 未決事項

No	内容	確認先	期限	ステータス
----	----	-----	----	-------

1.11 11. 変更履歴

日付	版数	変更内容	変更者
2026-05-17	1.0	初版作成	claude